

Security Linter Report

Filename	case3_sql_i_fstring.py
Timestamp	2026-06-05 04:29:00 UTC
Lines of Code (LOC)	5
Verdict	VULNERABLE

ID	Severity	Sink	Source Variable	Source Type	Line
CVE-SL-002	CRITICAL	cursor.execute	query	HTTP_ARGS	6

CRITICAL	1
WARNING	0
INFO	0
TOTAL	1

CVE-SL-002 — cursor.execute**CRITICAL**

CWE	CWE-89
Sink	cursor.execute
Sink Line	6
Sink Column	4
Sink Expression	cursor.execute(query)
Argument	query
Source Variable	query
Source Type	HTTP_ARGS
Propagation Mechanism	direct assignment from HTTP request

Taint Path Trace:

Step	Role	Line	Expression
1	SOURCE	5	query = f"SELECT * FROM users WHERE name = '{name}'"
2	SINK	6	cursor.execute(query)

Remediation:

Use a parameterized query. Never interpolate HTTP parameters directly into SQL:

```
name = request.args.get("name")
query = "SELECT * FROM users WHERE name = %s"
cursor.execute(query, (name,))
```

No safe sink paths confirmed.

No sanitization functions detected.

CFG — Total Nodes	8
CFG — Condition/Loop Nodes	0
CFG — Assignment Nodes	2
CFG — Call Nodes	1
CFG — Merge Nodes	1
██	██████████████
DFG — Total Nodes	11
DFG — Total Edges	10
DFG — Source Nodes	3
DFG — Sink Nodes	1
DFG — Operator Nodes	1
DFG — Constant Nodes	1
DFG — Variable Nodes	5
Taint Propagation Hops	5
██	██████████████
Analysis Time (ms)	11.4

Vulnerabilities	1 CRITICAL 0 WARNING 0 INFO
Safe Sinks	0
Analysis Time	11.4 ms
Engine Version	1.0.0
Final Verdict	VULNERABLE